

DPDP COMPLIANCE AUDIT

Agrivista

Digital Personal Data Protection Act 2023

73/100

Grade B

Adequate

Scanned: 25 March 2026

Files indexed: 17

Languages: express, mongoose, passport, passport-local, ejs, ejs-mate

CONFIDENTIAL — Internal Use Only

DPDP Compliance Scan Report

The application collects user credentials (username, email, password) and profile information (phone number, state, city, soil nutrient levels). The biggest DPDP risk is the potential for unauthorized access to user credentials and profile data due to the lack of explicit consent mechanisms for data collection and processing visible in the code.

Validation Summary Rule findings: 10 confirmed, 2 false positives suppressed • AI gaps: 2 dual-validated • Score: 76 (rules) → 73 (integrated)

Total findings: 12

HIGH: 3

MEDIUM: 3

INFO: 4

Tech Stack: express, mongoose, passport, passport-local, ejs

Risk Profile: The application collects user credentials (username, email, password) and profile information (phone number, state, city, soil nutrient levels). The biggest DPDP risk is the potential for unauthorized access to user credentials and profile data due to the lack of explicit consent mechanisms for data collection and processing visible in the code.

Compliance score by section

DPDP Section	Weight	Score	Status
Section 6	22	22/22 (100%)	PASS
Section 6(6)	8	0/8 (0%)	FAIL
Section 8(1)	18	18/18 (100%)	PASS
Section 8	10	10/10 (100%)	PASS
Section 8(3)	8	8/8 (100%)	PASS
Section 8(4)	8	0/8 (0%)	FAIL
Section 8(6)	8	6.8/8 (85%)	PASS
Section 9	6	6/6 (100%)	PASS
Section 11	6	2.1/6 (35%)	FAIL
Section 16	4	4/4 (100%)	PASS
Section 5	2	2/2 (100%)	PASS
Section 13 — Grievance Redressal	4	0/4 (0%)	FAIL

Estimated Total Remediation Effort: 2.0–6.8 engineering days

Data Flow Analysis

The following PII flow signals were inferred via static analysis (import/call adjacency). These are heuristic code-path chains, not proven runtime traces. Use them to guide developer review (confirm actual request → handler → service → database paths in your app).

Flow 1: Application Logs

PII fields: passport

app.js

Flow 2: Application Logs

PII fields: passport

app.js → CropPrediction.routes.js → CropPrediction.controllers.js

Flow 3: Application Logs

PII fields: passport

app.js → CropYieldPrediction.routes.js → CropYieldPrediction.controller.js

Flow 4: Application Logs

PII fields: passport

app.js → profile.routes.js → profile.controller.js

Flow 5: Application Logs

PII fields: passport

app.js → index.js

Rule	Section	Severity	File
CONSENT_WITHDRAWAL_MISSING	Section 6(6) — Consent Withdrawal	HIGH	N/A
AUDIT_TRAIL_MISSING	Section 8(4) — Audit Trail	HIGH	N/A
GRIEVANCE_OFFICER_MISSING	Section 13 — Grievance Redressal	HIGH	N/A
DATA_ACCESS_MISSING	Section 11 — Right to Access	MEDIUM	N/A
NO_BREACH_ALERTING	Section 8(6) — Breach	LOW	N/A
DATA_PORTABILITY_MISSING	Section 11 — Data Portability	LOW	N/A
INTERNAL_ROUTE_PII_ACCESS	Section 7 — Legitimate Use	INFO	src/app.js
NO_THIRD_PARTY_DETECTED	Section 5 — Notice	INFO	N/A
NO_THIRD_PARTY_DATA_SHARING	Section 5 — Purpose Limitation	INFO	N/A
NO_CROSS_BORDER_DETECTED	Section 16 — Cross-Border Transfer	INFO	N/A
	Section 5 — Purpose Limitation & Section 6 — Consent	MEDIUM	
	Section 6(1)(b) — Data Minimization	MEDIUM	

30-Day Remediation Roadmap

The following plan prioritises findings by severity and estimated effort. Complete Week 1 items before your next security review.

Week 1 — Critical (6–20 hours)

Fix immediately — these represent the highest legal exposure.

- Consent Withdrawal Missing (1–4 hrs)
- Audit Trail Missing (4–12 hrs)
- Grievance Officer Missing (1–4 hrs)

Week 2 — High Priority (6–22 hours)

Address within 2 weeks — short fixes with significant compliance impact.

- Data Access Missing (2–6 hrs)
- (2–8 hrs)

■ (2–8 hrs)

Week 4 — Advisory (4–14 hours)

Address before next compliance review.

- No Breach Alerting (2–6 hrs)
- Data Portability Missing (2–8 hrs)

Total estimated remediation effort: 16–56 hours (2.0–7.0 engineering days)

Changes Since 2026-03-25

▼ **Score: 76.0 → 73 (-3.0 points)**

- ✓ 1 finding(s) resolved
- 2 new finding(s) introduced
- 10 finding(s) unchanged

Resolved since last scan:

✓

New findings this scan:

- No Deletion Mechanism [HIGH]
- Retention Missing [MEDIUM]

Details

Finding 1 of 12

[Section 6(6) — Consent Withdrawal]

1. [HIGH] CONSENT_WITHDRAWAL_MISSING — N / A

Estimated fix time: 1–4 hours

Consent is collected but no withdrawal mechanism detected. DPDP Section 6(6) requires consent withdrawal to be as easy as giving consent. Users must be able to revoke consent at any time.

Risk:

The application is missing a mechanism for users to withdraw consent for data processing. This violates DPDP Section 6(6), potentially leading to continued processing of personal data against a user's wishes and regulatory penalties.

Fix:

1. Create a new route (e.g., `/consent/withdraw`) that allows authenticated users to revoke their consent.
2. Implement a controller function for this route that updates the user's consent status in the database to 'revoked'.
3. Ensure this withdrawal process is as easy to access as the consent giving process, potentially by adding a link in the user profile or footer.
4. Update relevant API endpoints to check and respect the user's consent status before processing their data.

DPDP:

Section 6(6) — Requires consent withdrawal to be as easy as giving consent.

Example:

```
app.get('/consent/withdraw', (req, res) => { // Logic to mark consent as withdrawn for the
current user // e.g., await User.findByIdAndUpdate(req.user._id, { consentGiven: false });
req.flash('success', 'Your consent has been withdrawn.');
```

Finding 2 of 12

[Section 8(4) — Audit Trail]

2. [HIGH] AUDIT_TRAIL_MISSING — N / A**Estimated fix time:** 4–12 hours

No audit trail infrastructure detected. DPDP Section 8(4) requires complete records of personal data processing activities. No access logging, audit model, or change tracking found in the codebase.

Risk:

The absence of an audit trail means there are no records of personal data processing activities. This violates DPDP Section 8(4), making it impossible to demonstrate compliance, investigate data breaches, or track data access, which can lead to significant legal and financial repercussions.

Fix:

1. Create a new Mongoose model (e.g., `AuditLog`) to store audit trail entries, including timestamp, user ID, action, and affected data.
2. Implement middleware in `src/app.js` to capture relevant request details (user, IP, endpoint, method) before processing.
3. After critical operations (data creation, update, deletion, access), log relevant details to the `AuditLog` model.
4. Consider using a dedicated logging library or service for more robust audit trail management.

DPDP:

Section 8(4) — Requires complete records of personal data processing activities.

Example:

```
// In a controller or service after a data modification: const auditLog = new AuditLog({
userId: req.user._id, action: 'UPDATE_PROFILE', details: 'Updated user profile information.',
timestamp: new Date() }); await auditLog.save();
```

Finding 3 of 12

[Section 13 — Grievance Redressal]

3. [HIGH] GRIEVANCE_OFFICER_MISSING — N / A**Estimated fix time:** 1–4 hours

No compliant Grievance Officer / DPO publication found. A PASS requires grievance-related text or a dedicated route ****and**** a contact email or dedicated grievance/DPO URL. Tiny repos without a grievance route are not marked PASS.

Risk:

The application lacks a designated contact point for grievance redressal, such as a Data Protection Officer (DPO) or a clear grievance contact. This contravenes DPDP Section 13, hindering users' ability to raise concerns or complaints about their data, and potentially leading to unresolved issues and regulatory non-compliance.

Fix:

1. Create a new route (e.g., `/contact/grievance`) that provides information on how to contact the grievance officer or DPO.
2. Add a dedicated email address or contact form for grievance submissions.
3. Display this contact information prominently on the website, such as in the footer or a dedicated 'Contact Us' or 'Privacy' page.
4. Ensure the contact details are accurate and monitored.

DPDP:

Section 13 — Requires provision for grievance redressal.

Example:

```
app.get('/contact/grievance', (req, res) => { res.render('grievance.ejs', { dpoEmail:
'dpo@example.com', // Replace with actual DPO email supportEmail: 'support@example.com' //
Replace with actual support email }); });
```

Finding 4 of 12

[Section 11 — Right to Access]

4. [MEDIUM] DATA_ACCESS_MISSING — N / A**Estimated fix time:** 2–6 hours

No endpoint detected that allows authenticated users to retrieve their own personal data. Under DPDP Section 11, Data Principals have the right to access information about their personal data being processed.

Risk:

The codebase does not demonstrate any explicit controls for managing access to personal data. This violates DPDP principles of data minimization and purpose limitation, potentially exposing sensitive information to unauthorized access or processing, leading to breaches and loss of user trust.

Fix:

1. Implement role-based access control (RBAC) to ensure users can only access data relevant to their role and permissions.
2. In API endpoints and data access layers, add checks to verify that the authenticated user has the necessary authorization to perform the requested action on the data.
3. Review all database queries to ensure they only retrieve the minimum necessary personal data for the specific task.
4. Consider implementing data masking or anonymization techniques for non-essential data fields.

DPDP:

General principles of data protection, including purpose limitation and data minimization, imply access controls.

Example:

```
function authorize(requiredRole) { return (req, res, next) => { if (res.locals.currentUser &&
res.locals.currentUser.role === requiredRole) { next(); } else {
res.status(403).send('Forbidden: Insufficient permissions.');
```

 } } }; // Example usage in a
route: app.get('/user/profile/:id', authorize('admin'), async (req, res) => { ... });

Finding 5 of 12

[Section 8(6) — Breach]

5. [LOW] NO_BREACH_ALERTING — N / A:26**Evidence snippet:** Defines the port for the Express server.**Estimated fix time:** 2–6 hours

Structured logging detected but no breach notification mechanism found. DPDP Section 8(6) requires notifying affected individuals and the Authority without undue delay when a breach occurs. Logging alone is insufficient — implement automated alerting (Sentry, PagerDuty, or equivalent) with escalation to a compliance team.

Risk:

The absence of a breach notification mechanism means that in the event of a data breach, affected individuals and the Data Protection Authority may not be notified promptly, leading to potential regulatory penalties and loss of trust.

Fix:

1. Integrate a monitoring and alerting service (e.g., Sentry, PagerDuty) into the application's error handling.
2. Configure the alerting service to trigger notifications for critical errors that could indicate a data breach.
3. Establish an escalation policy within the alerting service to notify a designated compliance team upon breach detection.
4. Implement a dedicated endpoint or process to handle breach notifications to affected individuals and the Authority as required by Section 8(6).

DPDP:

Section 8(6) — Breach notification requirements.

Example:

```
import * as Sentry from '@sentry/node'; // Initialize Sentry SDK
Sentry.init({ dsn: process.env.SENTRY_DSN, integrations: [ new Sentry.Integrations.Express({ app }) ] }); //
Other Express setup... // Error handler must be before any other error middleware
app.use(Sentry.Handlers.errorHandler()); // Custom error handler
app.use((err, req, res, next) => { // ... your existing error handling logic ... // Ensure breach notification logic is
  triggered here if applicable });
```


Finding 6 of 12

[Section 11 — Data Portability]

6. [LOW] DATA_PORTABILITY_MISSING — N / A:26**Evidence snippet:** Defines the port for the Express server.**Estimated fix time:** 2–8 hours

No data export or portability endpoint detected. DPDP Section 11 requires Data Fiduciaries to provide personal data in a commonly used, machine-readable format upon request.

Risk:

The lack of a data export or portability endpoint prevents users from accessing their personal data in a machine-readable format, which is a requirement under DPDP Section 11, potentially leading to non-compliance and user dissatisfaction.

Fix:

1. Create a new API endpoint (e.g., '/api/v1/data-portability') that accepts a user identifier.
2. In the endpoint handler, retrieve all personal data associated with the user from the database.
3. Format the retrieved data into a commonly used, machine-readable format such as JSON or CSV.
4. Return the formatted data as a file download or a JSON response to the user's request.

DPDP:

Section 11 — Data portability requirements.

Example:

```
import express from 'express'; import User from './models/user.model.js'; // Assuming User model has data const app = express(); app.get('/api/v1/data-portability', async (req, res) => { const userId = req.user._id; // Assuming user is authenticated try { const userData = await User.findById(userId).lean(); // Fetch user data // Format data to JSON res.setHeader('Content-disposition', 'attachment; filename=user_data.json'); res.json(userData); } catch (error) { res.status(500).send('Error exporting data'); } });
```

Finding 7 of 12

[Section 7 — Legitimate Use]

7. [INFO] INTERNAL_ROUTE_PII_ACCESS — src / app.js

Internal file (app.js) accesses PII. Verify access is restricted to authorised contexts and PII is not exposed to logs or error responses.

Finding 8 of 12

[Section 5 — Notice]

8. [INFO] NO_THIRD_PARTY_DETECTED — N / A

No known third-party analytics or tracking SDKs detected in codebase.

Finding 9 of 12

[Section 5 — Purpose Limitation]

9. [INFO] NO_THIRD_PARTY_DATA_SHARING — N / A

No third-party data sharing detected.

Finding 10 of 12

[Section 16 — Cross-Border Transfer]

10. [INFO] NO_CROSS_BORDER_DETECTED — N / A

No foreign cloud or non-India region config detected.

Finding 11 of 12

[Section 5 — Purpose Limitation & Section 6 — Consent]

11. [MEDIUM] — CODEBASE-WIDE

Missing initial purpose-specific consent for data collection

Finding 12 of 12

[Section 6(1)(b) — Data Minimization]

12. [MEDIUM] — CODEBASE-WIDE

Lack of data minimization practices for profile data

AI-Identified Compliance Gaps

The following gaps were identified by AI analysis and cross-validated. These are advisory observations, not verified rule violations. Human review is required before acting on these findings.

[AI-INFERRED] Missing initial purpose-specific consent for data collection

Confidence: 75%

Section 5 — Purpose Limitation & Section 6 — Consent

The repository context highlights 'No explicit consent mechanism for data collection visible in user registration (`src/controllers/user.controller.js`)' and for profile data. While consent withdrawal was checked, the rule engine did not explicitly verify the presence of initial, granular consent for each specific purpose of data collection (e.g., account creation, profile display, ML predictions).

Recommendation: Modify the user registration flow in `src/controllers/user.controller.js`` and profile update flow in `src/controllers/profile.controller.js`` to include explicit, purpose-specific consent mechanisms (e.g., checkboxes) before storing data in `src/models/user.model.js`` and `src/models/profile.model.js``.

[AI-INFERRED] Lack of data minimization practices for profile data

Confidence: 68%

Section 6(1)(b) — Data Minimization

The `src/models/profile.model.js`` defines a schema that collects fields such as `number`` and `city``. The repository context explicitly states 'No data minimization practices evident; all fields in profileSchema are collected'. There is no indication that these fields are optional or only collected when strictly necessary for the application's core functionality.

Recommendation: Review `src/models/profile.model.js`` and `src/controllers/profile.controller.js`` to assess the necessity of all collected profile data. Implement logic to make non-essential fields optional or remove them if they do not serve a clearly defined and necessary purpose.